AI Task Deployment Workflows

Vulnerabilities and Authentications Involved

IIT Madras
Secure System Engineering
Instructor: Prof. Narayanaswamy N S

Shubham Jadhav
CS24S009

May 13, 2026

Overview

Agentic AI Workflows

How AI agents are structured and operate autonomously to complete tasks.

Threat Landscape

Vulnerabilities and attacks targeting AI agent systems and LLM deployments.

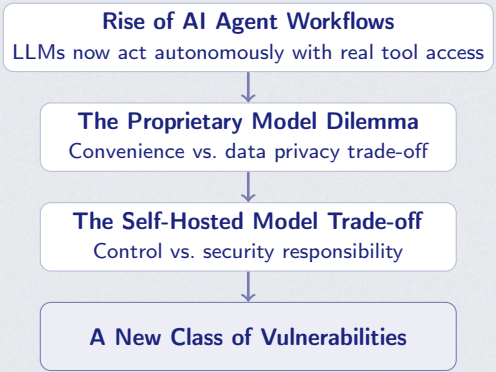
Demonstration

Indirect Prompt Injection - live attack walkthrough and mitigation strategies.

Motivation

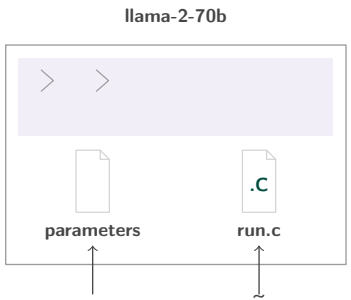
Why This Matters

- **Autonomous AI** — agents now schedule, query, and act on real systems
- **Proprietary APIs** — data leaves your infrastructure with every call
- **Self-hosted models** — security burden shifts entirely to your org
- **New attack surface** — agents expose threats that static LLMs do not



What is a Large Language Model?

An LLM is Just Two Files



What the Model Actually Does

Input Tokens (Prompt)

↓

LLM Forward Pass

↓

Next Token Prediction

Repeated autoregressively to generate full output.

How Training Works



Training compresses text into learned numerical weights.

Augmenting LLMs

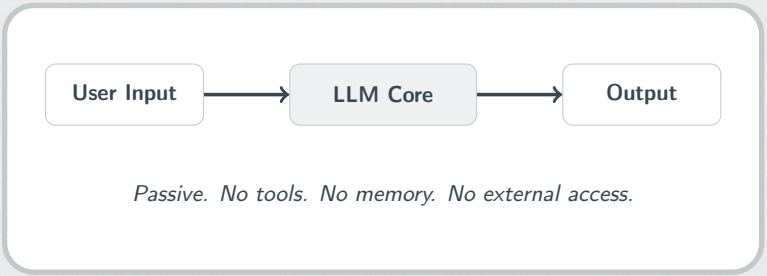
Part 1 — Limitations of LLMs

- **Lack of Controllability** — outputs are non-deterministic and hard to constrain
- **Poor Performance on Specialized Tasks** — general training misses domain depth
- **Limited Context Window** — cannot reason over long documents end-to-end
- **Hallucination** — confidently generates factually incorrect information

Part 2 — Augmentation Strategies

- **Prompt Engineering** — guide model behaviour through carefully structured inputs
- **Fine-Tuning** — adapt weights on domain-specific data for specialised tasks
- **RAG** — retrieve and inject relevant context at inference time
- **Agentic AI Workflows** — equip the model with tools, memory, and autonomy

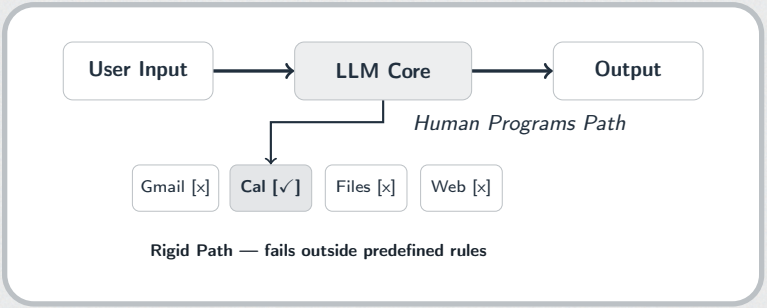
Agentic AI Workflows — Level 1: Vanilla LLM



Key Points

- Input → LLM → Output from training data only
- No private or personal data access
- Cannot reach tools, web, or files
- Passive — responds to prompt only

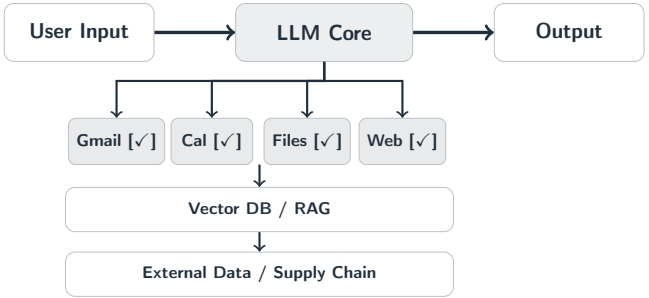
Agentic AI Workflows — Level 2: AI Workflow



Key Points

- Human programs a fixed path
- Only predefined tools in predefined order
- Fails outside programmed rules
- Human still does all reasoning

Agentic AI Workflows — Level 3: AI Agent

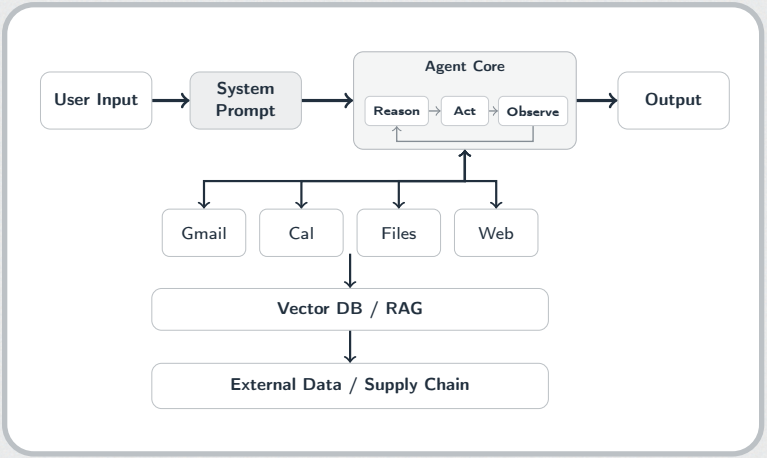


LLM is the decision maker. Autonomous. Iterative.

Key Points

- LLM becomes the decision maker
- Receives a goal — reasons, acts, observes
- All tools unlocked dynamically
- Fully autonomous — no human between steps

Agentic AI Workflows — The ReAct Framework



ReAct = Reason + Act

- Most common agent configuration
- **Reasons** about best approach
- **Acts** via tool/API, **observes** result
- Iterates until done — no human in loop

Threat Landscape Overview

Input / Prompt Layer

- Prompt Injection
- System Prompt Leakage

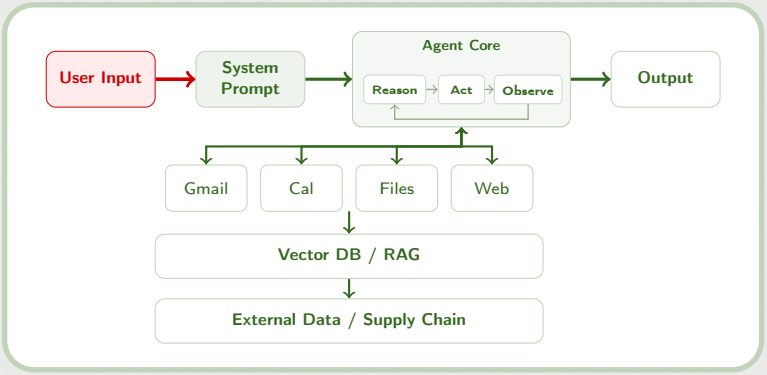
Agent Action & Output Layer

- Improper Output Handling
- Excessive Agency
- Unbounded Consumption

Data & Supply Chain Layer

- Sensitive Information Disclosure
- Supply Chain
- Data and Model Poisoning
- Vector and Embedding Weaknesses
- Misinformation

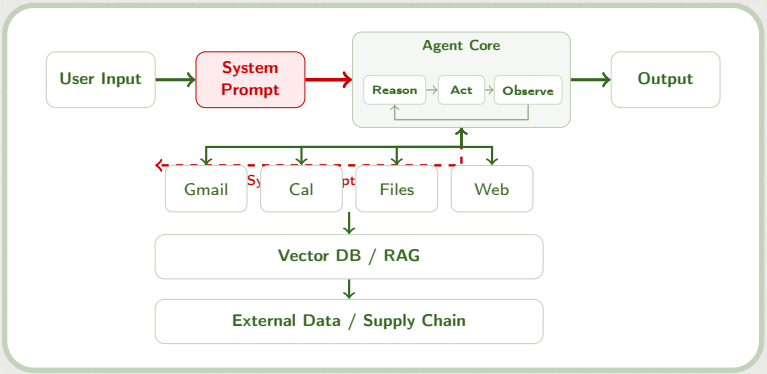
LLM01 — Prompt Injection



LLM01: Prompt Injection

- Attacker injects malicious instructions into user input
- Agent follows injected instructions instead of system prompt
- One injected instruction cascades through entire workflow
- Direct vs Indirect Prompt Injection

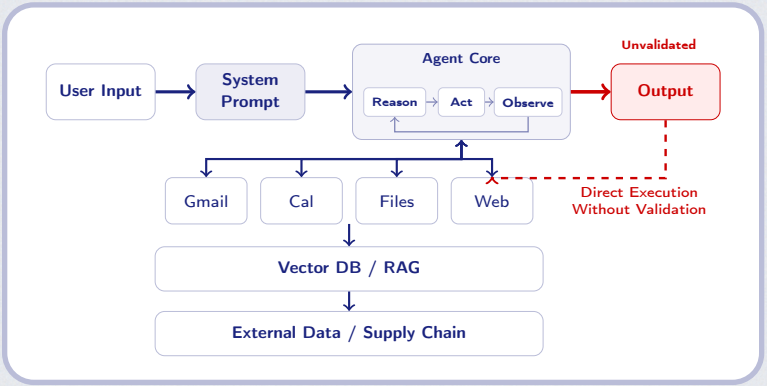
LLM07 — System Prompt Leakage



LLM07: Prompt Leakage

- System prompt contains internal logic, rules, and permissions
- Attacker crafts inputs to extract system prompt contents
- Reveals confidential business logic and security rules
- Enables more targeted follow-up attacks

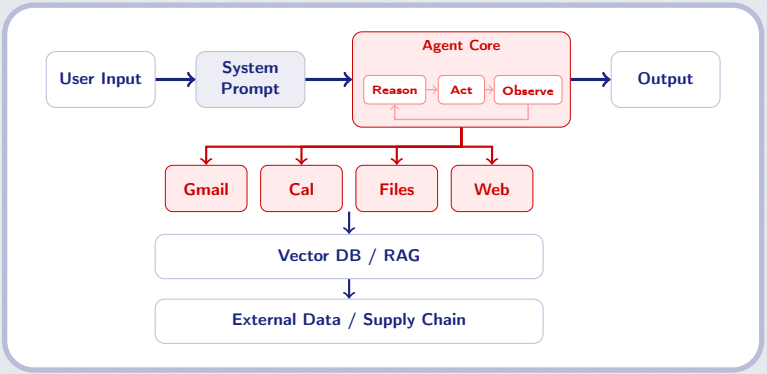
LLM05 — Improper Output Handling



LLM05: Output Handling

- LLM output passed to downstream systems without validation
- Malicious content in output triggers unintended execution
- Can lead to code execution, SQL injection, XSS
- Agentic systems amplify risk — output triggers tool calls

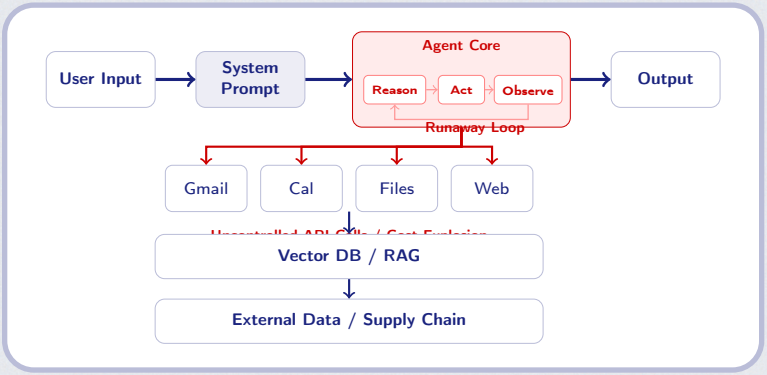
LLM06 — Excessive Agency



LLM06: Excessive Agency

- Agent granted more permissions than necessary
- Violates principle of least privilege
- Compromised agent can cause irreversible damage
- Unchecked autonomy — acts beyond intended scope

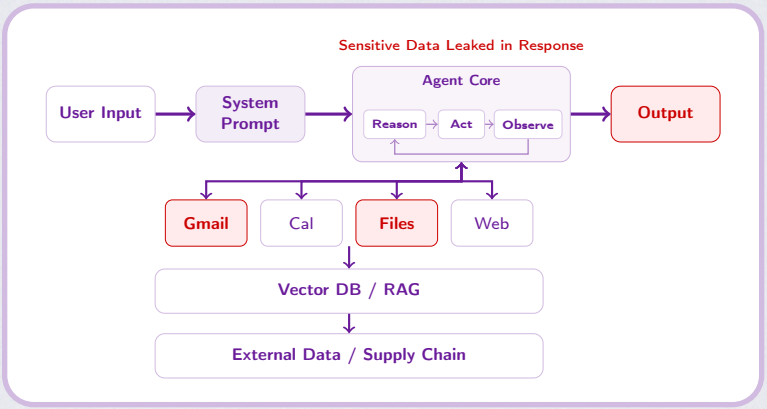
LLM10 — Unbounded Consumption



LLM10: Unbounded Consumption

- Attacker triggers excessive LLM usage intentionally
- Resource exhaustion — compute, memory, API costs
- Denial of service through runaway agent loops
- Financial damage through uncontrolled API billing

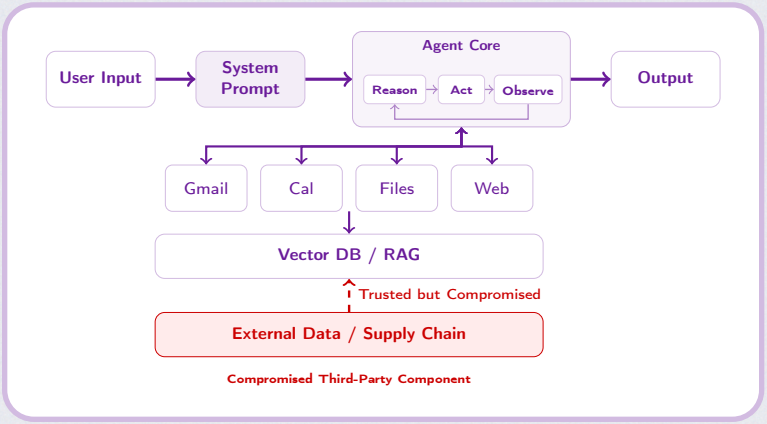
LLM02 — Sensitive Information Disclosure



LLM02: Info Disclosure

- LLM inadvertently reveals private data through outputs
- Training data memorization — model recalls sensitive info
- API keys, credentials, PII leaked through responses
- Agent exposes data from connected tools

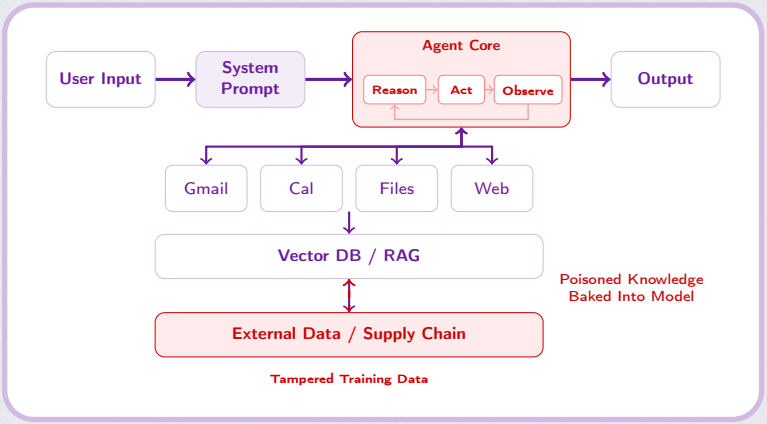
LLM03 — Supply Chain



LLM03: Supply Chain

- Compromised third-party components — models, plugins, datasets
- Malicious code injected into dependencies
- Attacker compromises upstream to affect all downstream users
- Trust in third-party integrations is a hidden attack surface

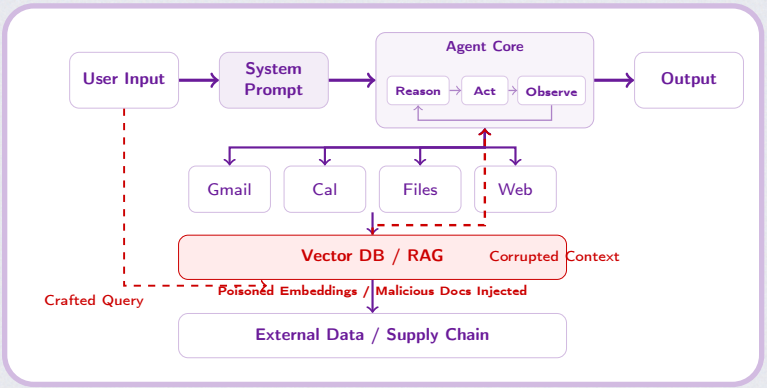
LLM04 — Data and Model Poisoning



LLM04: Model Poisoning

- Attacker tampers with training or fine-tuning data
- Poisoned data introduces hidden behaviors or backdoors
- Model behaves normally until trigger condition is met
- Compromises security, accuracy, and ethical behavior

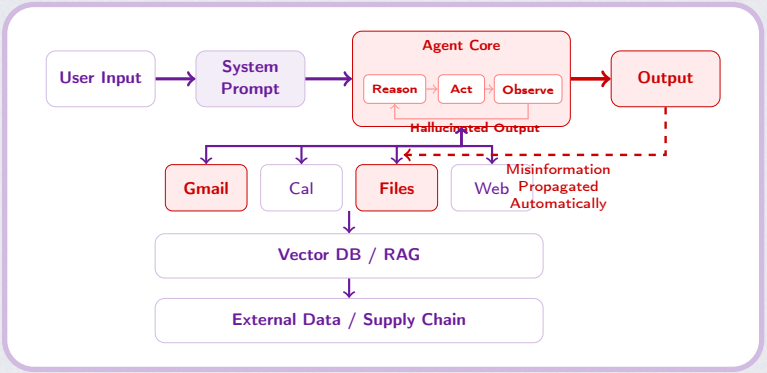
LLM08 — Vector and Embedding Weaknesses



LLM08: Embedding Weaknesses

- Vulnerabilities specific to RAG and vector databases
- Malicious documents injected into vector store
- Crafted queries retrieve unintended documents
- Attacker manipulates what context the agent retrieves

LLM09 — Misinformation



LLM09: Misinformation

- LLM generates and propagates false information confidently
- Especially dangerous when agent outputs are trusted blindly
- Hallucination at scale — automated misinformation in workflows
- Downstream systems act on incorrect agent outputs

Demonstration

Indirect Prompt Injection

Conclusion

- AI Agent Workflows : Power Comes With Risk
- Every Layer is an Attack Surface
- Indirect Prompt Injection : #1 Active Threat Today
- Security Cannot Be an Afterthought

Future Scope

1. Proposed Gateway

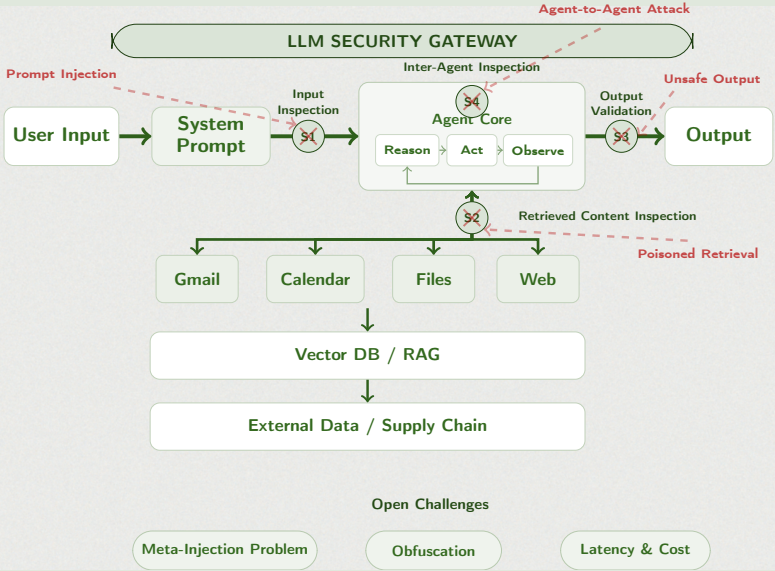
A green inspection layer sits across every agent communication path.

2. What It Does

Inspects inputs, retrieved content, outputs, and inter-agent reasoning hops before they execute.

3. Visual Goal

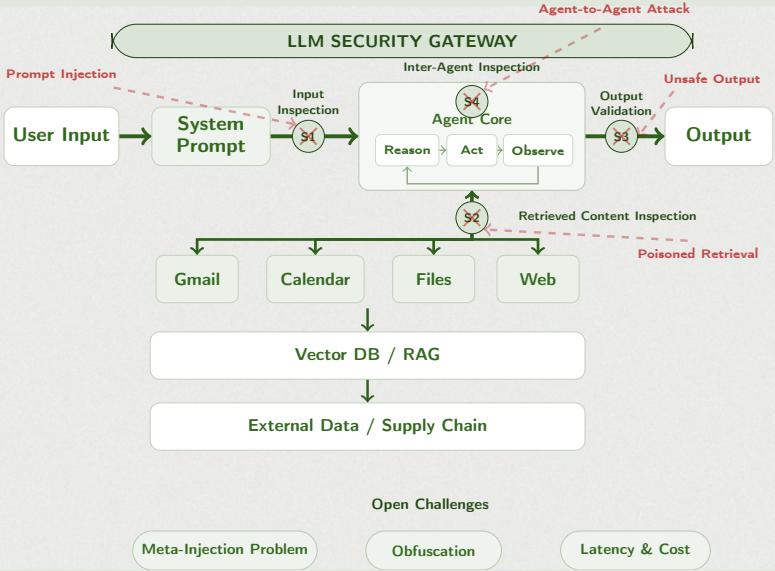
Faded red attack paths are intercepted at four checkpoints by the LLM Security Gateway.



Future Scope

1. Proposed Gateway

A green inspection layer sits across every agent communication path.



Thank You

Questions?